Audit de sécurité — Nhill 3.0.0

English: ../en/03-security-audit.md

> **Date :** 28 octobre 2026 · **Nature :** revue de code et de configuration (« boîte blanche »), tests automatisés exécutés, essais des outils d'exploitation sur une machine Ubuntu 24.04 neuve en intégration continue, vérification des dépendances contre des bases de vulnérabilités publiques. **Ce n'est pas un test d'intrusion** et aucune affirmation d'absence de vulnérabilité n'est faite. L'audit précédent (0.1.0 → 2.0.0, 26 octobre 2026) est résumé au § 6.

1. Synthèse

Le modèle de sécurité reste celui de la version 2 : le serveur décide de tout (rôles, formule, abonnement), chaque établissement est isolé par la sécurité au niveau des lignes de PostgreSQL, imposée par la base, les mots de passe sont conservés sous forme d'empreinte Argon2id, les jetons sont opaques, courts et tournants, l'administration de la plateforme exige une double authentification, les sauvegardes sont chiffrées.

La version 3.0.0 ajoute des surfaces nouvelles (formules et droits, facturation de la console, prestataires de paiement, caisse, export complet, suppression d'établissement, outils de serveur privé virtuel, site vitrine et ses formulaires). Elles ont été revues ; quatre écarts ont été corrigés pendant l'audit (§ 3) et deux risques restent ouverts avec une décision à prendre (§ 4, R1 et R2).

#	Risque	Gravité	Statut 3.0.0
R1	**cpp-httplib 0.14.3** (paquet Ubuntu 24.04) : CVE-2025-46728 et CVE-2025-53629, mémoire non bornée avec des corps de requête « chunked » ; correctifs publiés seulement par Ubuntu Pro (ESM). Le paquet serveur Debian 13 est construit contre `0.18.7-1+deb13u1`, indiqué corrigé pour ces deux CVE par le Debian Security Tracker (consulté le 29/10/2026)	Haute	**Ouvert, atténué** (paquet Ubuntu 24.04, celui du VPS) : le serveur écoute sur 127.0.0.1 ; Caddy refuse les corps de plus de 6 Mo avant le serveur. Correction proposée : construire contre cpp-httplib ≥ 0.23 (en-tête unique). **Décision requise** (§ 4)
R2	**Qt 6.5.3** embarqué dans les installateurs Windows et l'APK Android (avis publiés après 6.5.3, notamment HTTP/2 : CVE-2023-51714, CVE-2024-39936)	Haute	**Atténué en 3.0.0** : HTTP/2 désactivé dans le client (HTTP/1.1 seulement). Correction complète : version de Qt maintenue ; impact sur la version minimale d'Android à évaluer. **Décision requise**
R3	Longueur minimale des mots de passe : 8 caractères (exigence du propriétaire)	Moyenne	Risque accepté, compensé (§ 5)
R4	Sauvegarde quotidienne seulement : jusqu'à 24 heures de données perdues en cas de perte du serveur	Moyenne	Ouvert — archivage continu des journaux de transactions (WAL) recommandé
R5	Messagerie de `nhill.online` non configurée (aucun MX, SPF ni DMARC) : usurpation d'adresse facilitée, messages automatiques non délivrables	Moyenne	Ouvert — configuration DNS à faire par l'exploitant
R6	Fournisseur de fichiers Android déclaré sur tout l'espace privé de l'application	Faible	Accepté : fournisseur non exporté, accès accordé fichier par fichier par l'application
R7	Pas d'audit externe ni de test d'intrusion	—	Ouvert — avant une ouverture commerciale large

2. Périmètre et modèle de menace

- **Actifs :** données commerciales des établissements, comptes et sessions, secrets (`NH_SECRET_KEY`, secrets des prestataires et des webhooks, identifiants de base), clé privée des sauvegardes, journal d'activité, demandes reçues par le site.
- **Acteurs considérés :** internaute anonyme ; utilisateur d'un autre établissement ; employé aux droits limités (caissier, vendeur) ; ancien employé ; détenteur d'un code d'établissement ; administrateur de la console aux droits limités (support, facturation, auditeur) ; attaquant réseau ; prestataire de paiement usurpé ; robot visant les formulaires du site.
- **Hors périmètre :** compromission du poste de l'utilisateur ou de l'hébergeur, attaques physiques, déni de service volumétrique.

3. Contrôles vérifiés en 3.0.0

Domaine	Contrôle	Preuve
Formules et droits	Chaque route déclare son droit ; une fonction absente de la formule est refusée par le serveur, pas seulement masquée	`http/app.cpp`, `entitlements.cpp` ; tests `Plans.*`
Accès selon l'abonnement	Accès calculé par la base à partir des dates (complet, lecture seule, aucun) ; écritures refusées en lecture seule, exports permis	`nh_subscription_access` (`0012`) ; tests `Billing.*`
Console	Rôles `superadmin`, `billing`, `support`, `auditor` vérifiés par route ; double authentification TOTP non rejouable	`admin.cpp`, `console.cpp` ; tests `Admin.*`, `Console.*`
Paiements	Les droits ne changent qu'après une notification vérifiée (signature, horodatage, montant) ou un enregistrement par l'équipe ; traitement idempotent ; secrets des prestataires chiffrés, jamais relus par la console	`subscriptions.cpp`, `providers.cpp` ; tests `Webhook.*`, `Providers.*`
Caisse	Accord de responsable : mot de passe du responsable, une autre personne que le demandeur, jeton à usage unique lié à l'action, au demandeur et à la session, valable 3 minutes ; tentatives limitées ; refus journalisés	`pos.cpp` (`consumeApproval`, `/pos/approvals`) ; tests `Pos.*`
Clôture à l'aveugle	Le montant attendu n'est jamais renvoyé avant la clôture ; session close immuable	`pos.cpp`, `nh_guard_pos_session`
Export complet	Titulaire seulement, 3 exports par 15 minutes, aucun mot de passe, jeton ni code dans l'archive	`export.cpp`
Suppression d'établissement	Super-administrateur seulement, nom commercial à saisir, jamais avec un accès complet ; le rôle applicatif ne peut pas utiliser le drapeau de suppression (les déclencheurs exigent le rôle propriétaire)	`0014_establishment_erasure.sql`, `admin.cpp` ; 6 tests `Erasure.*`, `Retention.*`
Rétention	Messages envoyés supprimés après 30 jours, sessions terminées après 90 jours, journaux du serveur 90 jours	`jobs.cpp`, `deploy/vps/provision.sh` ; test `Retention.*`
Recherche	Les caractères `%` et `_` saisis sont pris littéralement (motifs `LIKE` échappés)	`0015_search_patterns.sql` ; test `Search.*`

Domaine	Contrôle	Preuve
Serveur privé virtuel	Base et API à l'écoute sur 127.0.0.1 seulement ; pare-feu actif ; fichiers de secrets en 0600 ; aucun superutilisateur temporaire restant ; clé privée des sauvegardes absente du serveur ; HTTPS avec HSTS et redirection HTTP	`deploy/vps/tests/acceptance.sh` : **12 contrôles réussis** sur une machine neuve (CI `vps-test`, 28/10/2026)
Sauvegardes	`pg_dump` chiffré par `age` sans copie en clair ; restauration d'essai sur une instance jetable, hors du serveur, sous un compte non privilégié ; isolation vérifiée après restauration	`nhill-backup.sh`, `nhill-restore-test.sh` ; contrôle 07 de la recette
Mise à jour	Somme de contrôle du paquet obligatoire ; sauvegarde et copie de la base avant ; retour arrière automatique ; un ancien serveur refuse une base migrée par une version plus récente	`nhill-update.sh`, `nhill-rollback.sh`, `migrate.cpp` ; contrôles 08 à 11 de la recette, test `Setup.*`
Surveillance	Contrôle toutes les 5 minutes (service, base, HTTPS, certificat, ports, pare-feu, disque, sauvegarde) et alerte	`nhill-healthcheck.sh`, `nhill-alert.sh` ; contrôle 06 de la recette
Site vitrine	Aucun cookie ni ressource externe ; politique de sécurité du contenu sans style ni script en ligne ; formulaires : origines autorisées, JSON seulement, 16 Ko maximum, champ piège, délai minimal, limites par adresse et par jour, rôle de base en insertion seule, empreinte d'adresse IP effacée après 30 jours	`website/backend` ; 13 tests du backend ; `tools/check_site.py`
Client	HTTPS obligatoire sauf adresse locale ; jeton de rafraîchissement dans le trousseau du système ; **HTTP/2 désactivé** (R2) ; Android : fournisseur de fichiers non exporté, autorisation par fichier	`apiclient.cpp`, `session.cpp`, `AndroidManifest.xml`
Secrets du dépôt	Recherche de motifs (clés de prestataires, clés privées, jetons, clés `age`) : aucun secret hors exemples	recherche automatisée du 28/10/2026

Écarts trouvés et corrigés pendant l'audit :

1. Aucune suppression des données d'un établissement n'existait, alors que les conditions promettent la suppression 90 jours après la fin du contrat → migration 0014, action de la console, tests.
2. Messages automatiques et sessions terminées conservés sans limite (adresses e-mail, adresses IP) → suppression quotidienne après 30 et 90 jours.
3. Recherches `ILIKE` avec `%` et `_` non échappés (risque S9 de l'audit 2.0) → corrigé.
4. Fichier de contrôle des sauvegardes lié au répertoire du serveur : la vérification échouait sur une copie externe → nom de fichier seul, comparaison de l'empreinte.

4. Décisions requises

Risque	Option recommandée	Effet
R1 cpp-httplib	Livrer avec le serveur une copie vérifiée de cpp-httplib ≥ 0.23 (en-tête unique, licence MIT), version et empreinte consignées ; ou utiliser les paquets corrigés d'Ubuntu Pro ; ou installer le serveur de production sur Debian 13 (paquet corrigé par Debian), ce qui demande d'adapter et de recetter `deploy/vps` pour Debian 13	supprime la vulnérabilité au lieu de l'atténuer ; à refaire à chaque avis

Risque	Option recommandée	Effet
R2 Qt	Construire Windows et Android avec une version de Qt maintenue	supprime les avis publiés après 6.5.3 ; la version minimale d'Android peut monter (à vérifier avant de changer le site)

5. Politique de mots de passe (rappel de la décision 2.0)

Minimum 8 caractères (points de code), sans règle de composition ni changement périodique ; refus des mots de passe courants, répétitifs ou égaux à l'e-mail ; limitation des tentatives ; Argon2id ; fermeture des autres sessions au changement. Double authentification obligatoire pour la console, non imposée aux établissements. Pour un mot de passe utilisé seul, NIST SP 800-63B-4 recommande 15 caractères : risque accepté (R3).

6. Suivi de l'audit 2.0.0

2.0	Risque	État en 3.0.0
S1	cpp-httplib 0.14	toujours ouvert → R1
S2	Qt 6.4.2 embarqué dans les paquets Debian 13	corrigé en 2.0 (paquets natifs) ; Qt 6.5.3 de Windows et Android → R2
S3	Aucune récupération de compte	corrigé en 2.1 (code par e-mail, mot de passe temporaire)
S4	8 caractères	risque accepté → R3
S5	`X-Forwarded-For` lu à gauche	corrigé en 2.0
S6	Conformité « données personnelles »	dossier juridique 3.0.0 (`legal/fr/00-recherche-juridique.md`) ; formalités à accomplir par l'exploitant
S7	Pas d'archivage continu des WAL	toujours ouvert → R4
S8	Pas de supervision	corrigé en 3.0 (contrôles toutes les 5 minutes, alertes)
S9	`ILIKE` non échappé	corrigé en 3.0

7. Sources

- NVD — CVE-2025-46728 : https://nvd.nist.gov/vuln/detail/CVE-2025-46728
- NVD — CVE-2025-53629 : https://nvd.nist.gov/vuln/detail/CVE-2025-53629
- OSV — UBUNTU-CVE-2025-53629 (paquets cpp-httplib d'Ubuntu 24.04) : https://osv.dev/vulnerability/UBUNTU-CVE-2025-53629
- Ubuntu — USN-7962-1, cpp-httplib (correctifs 24.04 par ESM) : https://ubuntu.com/security/notices/USN-7962-1
- Debian Security Tracker — CVE-2025-46728 et CVE-2025-53629 (cpp-httplib, trixie : 0.18.7-1+deb13u1 corrigé) : https://security-tracker.debian.org/tracker/CVE-2025-46728 , https://security-tracker.debian.org/tracker/CVE-2025-53629
- Debian Security Tracker — CVE-2024-39936 (Qt, HTTP/2) : https://security-tracker.debian.org/tracker/CVE-2024-39936
- NVD — CVE-2023-51714 (Qt, HTTP/2 HPACK) : https://nvd.nist.gov/vuln/detail/CVE-2023-51714
- NIST SP 800-63B-4 : https://pages.nist.gov/800-63-4/sp800-63b.html